

## Manual 52 — Ciberseguridad de IA: ciclo de vida seguro, OWASP y MITRE ATLAS

Fuente controlada de publicación — Español (Latinoamérica)

Fecha de verificación: 1 de septiembre de 2026

### Propósito

Este manual establece un modelo práctico de ciberseguridad para sistemas de IA durante diseño, desarrollo, integración, despliegue, operación, cambio y retiro. Trata la IA generativa, RAG y la IA agéntica como sistemas con límites de confianza, identidades, herramientas, flujos de datos y rutas de ataque específicas.

### Disciplina de fuentes

La guía OWASP GenAI y Agentic es orientación comunitaria de seguridad. MITRE ATLAS es una base de conocimiento adversarial viva. NIST AI RMF 1.0 y NIST AI 600-1 son referencias voluntarias de gestión de riesgos. Ninguna se presenta como certificación legal ni como prueba de cumplimiento regulatorio.

### AC-01 — Inventario de activos y dependencias de IA

Inventariar modelos, APIs, agentes, almacenes RAG, pipelines, herramientas, identidades, secretos, orquestación, hosting y terceros; registrar propietario, propósito, versión, datos, permisos y estado.

### AC-02 — Arquitectura de límites de confianza

Documentar límites entre usuarios, contenido no confiable, prompts, instrucciones del sistema, runtime, RAG, herramientas, agentes, servicios externos y sistemas privilegiados.

### AC-03 — Inyección de prompt directa e indirecta

Evitar que contenido no confiable adquiriera autoridad de instrucción. Separar política confiable de contenido recuperado, validar llamadas a herramientas, limitar acciones y probar rutas de inyección indirecta.

### AC-04 — Envenenamiento de RAG/fuentes

Controlar aprobación, procedencia, ingestión, autorización, integridad, vigencia y recuperación. Probar fuentes envenenadas, no autorizadas, obsoletas y engañosas.

### AC-05 — Divulgación y exfiltración de datos sensibles

Proteger prompts, contexto, datos RAG, salidas, registros y respuestas de herramientas con autorización, minimización, filtrado, monitoreo y pruebas de fuga.

### AC-06 — Manejo inseguro de salidas

Tratar la salida del modelo como no confiable cuando pase a shells, intérpretes, SQL, plantillas, navegadores, APIs o automatización. Validar, parametrizar, aislar y aprobar operaciones consecuentes.

### **AC-07 — Agencia excesiva y abuso de herramientas**

Limitar herramientas, permisos, transacciones, autonomía y recursos. Exigir aprobación humana cuando corresponda y conservar trazabilidad atribuible.

### **AC-08 — Identidad y delegación de agentes**

Usar identidades atribuibles, credenciales con alcance limitado y límites explícitos de delegación. Revalidar autorización en cada salto entre agentes y herramientas.

### **AC-09 — Seguridad de secretos y credenciales**

Usar gestores de secretos y credenciales de corta duración cuando sea viable, con rotación y revocación rápida. No incrustar secretos duraderos en prompts o memoria.

### **AC-10 — Cadena de suministro de modelo/datos/software**

Rastrear versiones de modelo/proveedor, librerías, contenedores, datasets, plugins, herramientas y dependencias. Aplicar controles de integridad y disparadores de revalidación.

### **AC-11 — Envenenamiento de modelos y datos**

Proteger datos de entrenamiento, ajuste, evaluación y recuperación contra modificación no autorizada o contenido malicioso. Mantener procedencia e integridad.

### **AC-12 — Extracción, robo y abuso del modelo**

Aplicar autenticación, autorización, límites de uso y monitoreo de anomalías según exposición y valor. Detectar scraping, enumeración y sondeo repetido de límites.

### **AC-13 — Agotamiento de recursos / denegación de servicio**

Controlar tokens, cómputo, recursión, llamadas de herramienta, API y transacciones mediante cuotas, timeouts, límites de recursión y circuit breakers.

### **AC-14 — Monitoreo y detección de seguridad**

Recolectar telemetría de autenticación, uso de herramientas, denegaciones de política, prompts/acciones anómalas, eventos RAG, cambios de modelo y acciones de contención.

### **AC-15 — Pruebas adversariales y red teaming**

Probar inyección de prompt, envenenamiento RAG, abuso de herramientas, fuga de datos, escalamiento de privilegios, ejecución insegura, abuso del modelo, manipulación de supply chain y fallas de contención.

### **AC-16 — Gestión de vulnerabilidades y cambios**

Rastrear vulnerabilidades y tratar cambios de modelo, proveedor, herramienta, permiso, política, fuente RAG u orquestación como posibles disparadores de revalidación.

### **AC-17 — Seguridad de terceros de IA**

Evaluar proveedores externos por seguridad, identidad, manejo de datos, notificación de cambios, incidentes, continuidad, subcontratistas y acceso a evidencia.

## AC-18 — Respuesta a incidentes de IA

Preservar versión de modelo/proveedor, prompts, contexto, registros RAG/herramienta/agente, identidades, exposición de datos, detecciones y evidencia de contención.

## AC-19 — Contención, rollback y deshabilitación de emergencia

Mantener capacidad probada para deshabilitar agentes/herramientas, revocar credenciales, aislar entornos, bloquear endpoints y restaurar configuración segura.

## AC-20 — Retiro seguro

Revocar credenciales, eliminar acceso, archivar evidencia requerida, aplicar retención/eliminación, retirar integraciones y actualizar inventario.

## Escenarios adversariales obligatorios

1. Inyección indirecta mediante RAG.
2. Uso de herramientas por agente sobreprivilegiado.
3. Cambio de versión del modelo por proveedor.
4. Exfiltración de datos vía RAG.
5. Ejecución insegura de salida.
6. Abuso de delegación entre agentes.
7. Manipulación de modelo o artefacto en supply chain.
8. Jailbreak combinado con invocación de herramientas.
9. Envenenamiento de datos de entrenamiento/evaluación.
10. Respuesta a incidentes con telemetría incompleta.

Cada escenario debe producir evidencia de prevención, detección, contención, recuperación, revalidación y escalamiento. No se aprueba solo porque el resultado dañino no ocurrió.

## Registro mínimo de evidencia

- AC-E01 inventario de activos y dependencias.
- AC-E02 modelo de amenazas y límites de confianza.
- AC-E03 paquete de pruebas de prompt/RAG.
- AC-E04 diseño de autorización y delegación de agentes.
- AC-E05 evaluación de cadena de suministro e integridad.
- AC-E06 resultados adversariales/red team.
- AC-E07 mapa de telemetría y detección.
- AC-E08 paquete de evidencia de incidentes.
- AC-E09 registro de cambios y revalidación.
- AC-E10 prueba de recuperación y contención.

## Método de crosswalk

Cada fila debe registrar control empresarial → relación OWASP → relación MITRE ATLAS cuando aplique → apoyo NIST → evidencia → limitaciones → riesgo residual. Manual 46 aporta la columna vertebral de gobierno de IA; Manual 51 aporta identidad, autonomía,

límites de acción, autoridad delegada y responsabilidad humana; Manual 52 agrega modelado adversarial, detección, red teaming, contención técnica y evidencia de incidentes.

### **Regla de liberación**

Un control no se considera efectivo solo porque exista documentación. Se requiere evidencia de implementación, prueba, manejo de excepciones y disposición del riesgo residual. Cambios materiales de fuente o plataforma obligan a reevaluar.